

General Categories of Security Attacks

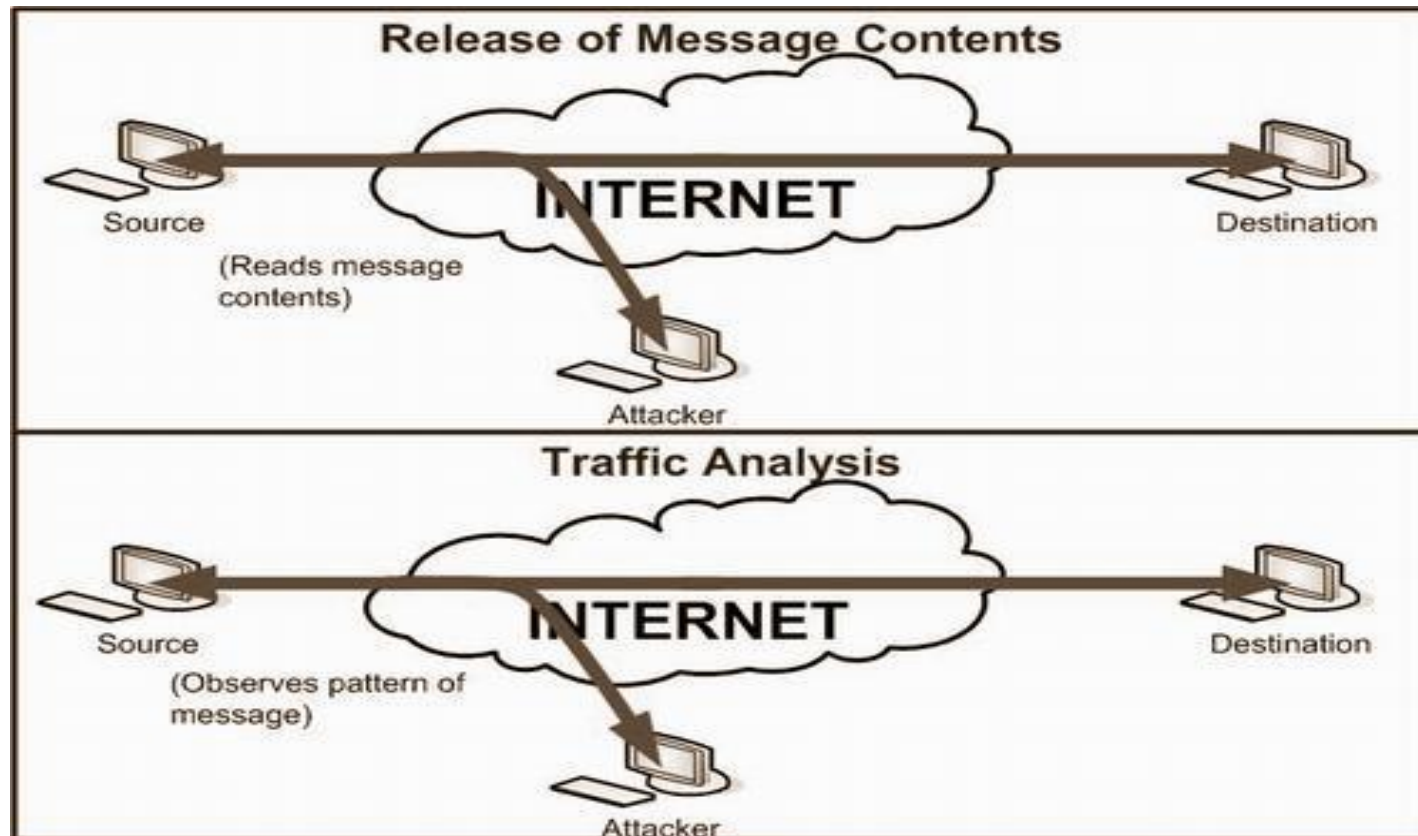
Secure system

- A system which is providing the services required by the user accurately and preventing the illegal use of system resources is called a secure system.
- Any action that compromises the security is called a security attack.

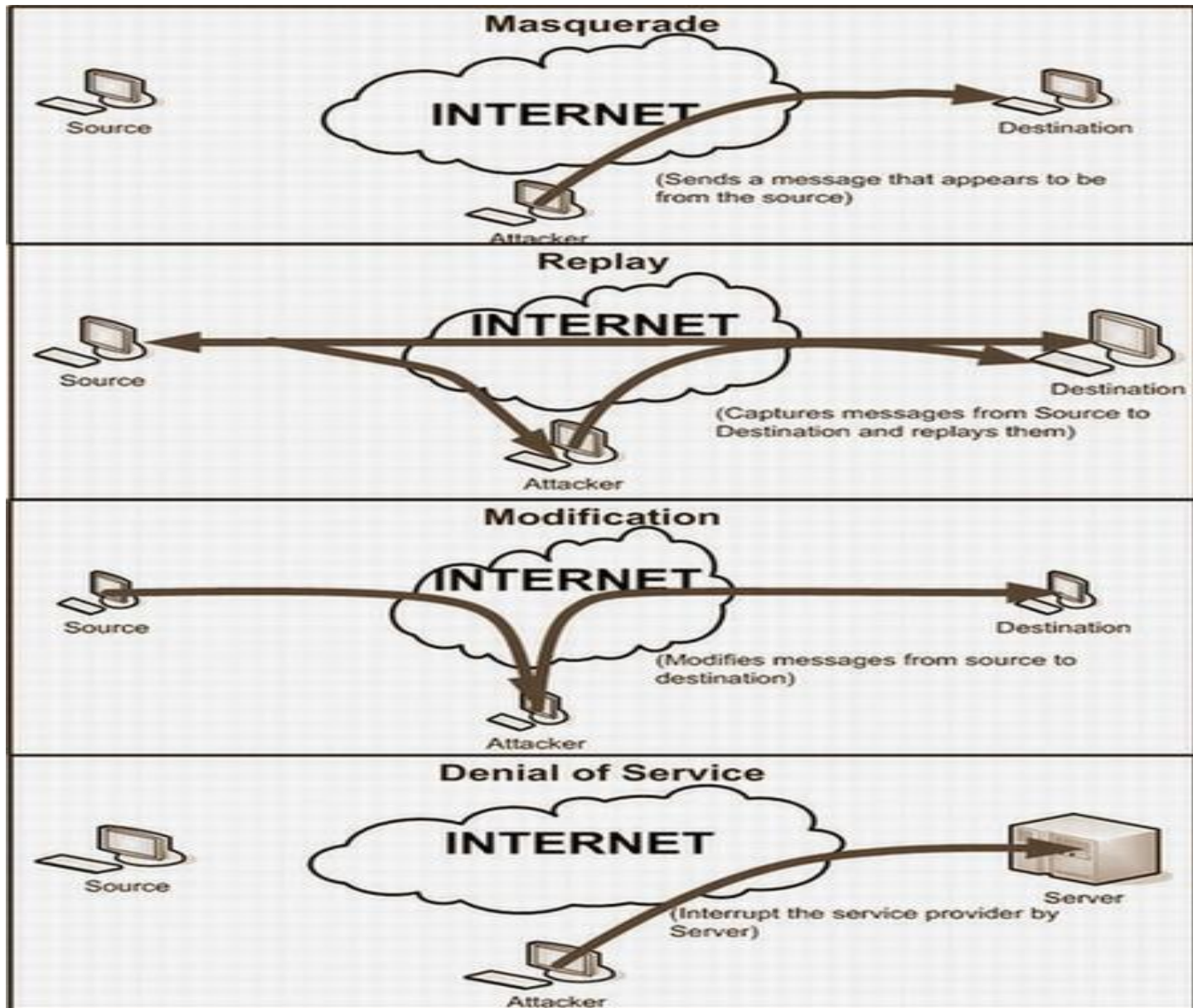
- Attacks can be categorized into following basic categories:
 - Interruption (attack on availability)
 - Interception(attack on confidentiality)
 - Modification (attack on integrity)
 - Fabrication (attack on authenticity)

- We can further classify security attacks as *passive attacks* and *active attacks*.
- **Passive attacks** are only involved in monitoring of the information(interception). The goal of this attack is to obtain transmitted information.

- Two types of passive attacks are
 - *release of message content*
 - *traffic analysis*



- Active attacks are involved in modification of data (interception, modification, fabrication) or creation of false data.
- These attacks are further subdivided into four categories:
 - *Masquerade*
 - *Replay*
 - *modification of data*
 - *denial of service*



Reconnaissance Attacks

- Gathering information against a targeted host or network is called reconnaissance attack.
- Attackers analyze the target host and try to discover the details:
 - alive IP addresses
 - open ports of the network
 - failure of operating system
 - types of services and protocols running

- Some basic reconnaissance attacks are:
 - Packet Sniffers
 - Port scan and ping sweep
 - Internet information queries

Packet Sniffers

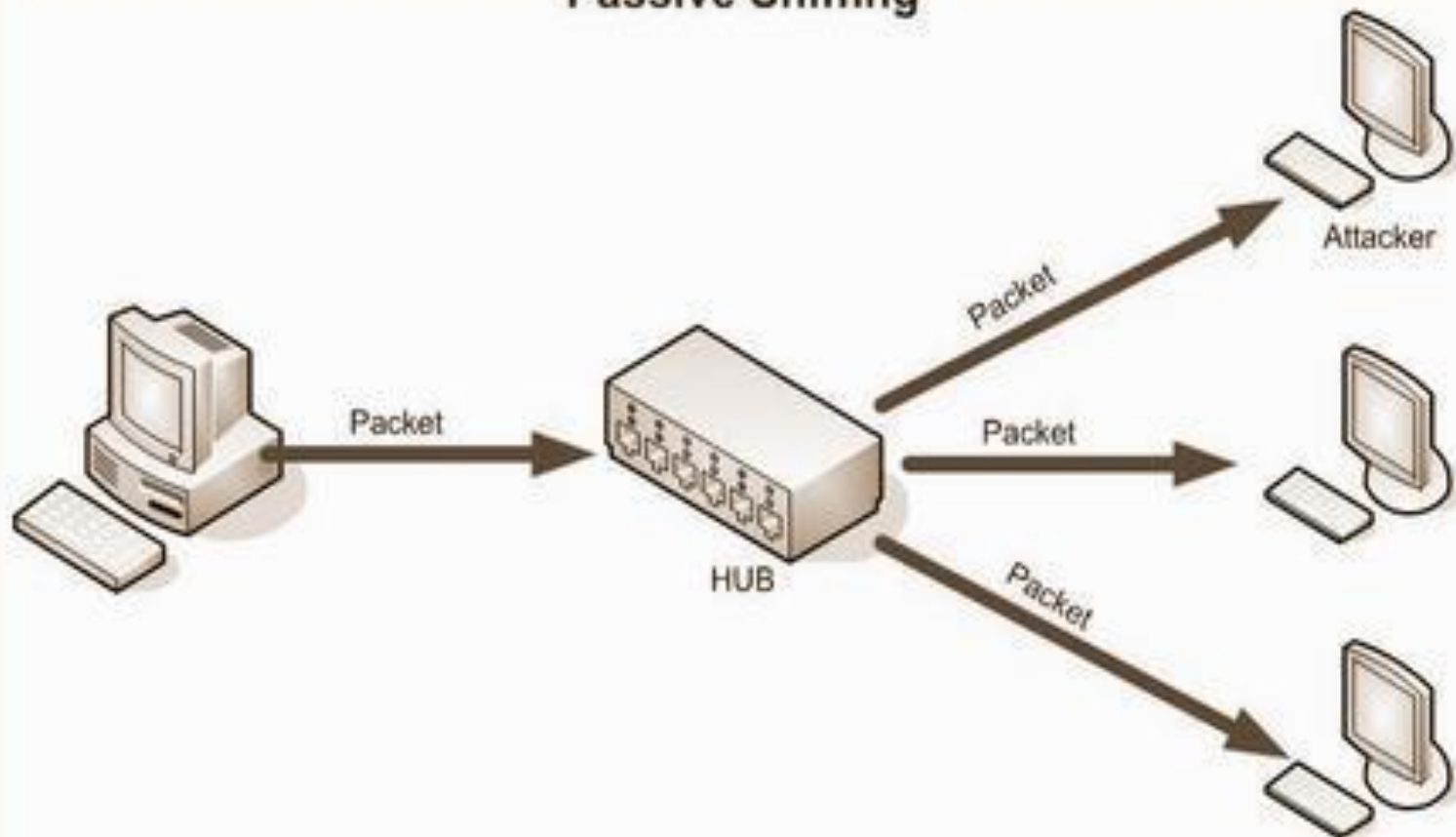
- Packet sniffer is a tool or device that can be used for capturing the packet at data link layer.
- Can be used both by the hacker for eavesdropping and by the administrators for network monitoring and troubleshooting
- *Tcpdump*, *windump*, *wireshark* are examples of different sniffing tools.

- Sniffing can be of two types depending on the network.
 - Passive Sniffing
 - Active Sniffing

Passive Sniffing

- Passive sniffing is used in hubbed networks.
- hard to detect because it generates no traffic on network.
- To avoid passive sniffing most of the networks nowadays are using switches instead of hubs.

Passive Sniffing



Active Sniffing

- Active sniffing is performed on switched network
- Switch worked as a central entity, rather than broadcasting
- Switches worked on the basis of MAC addresses.

- They maintain an address resolution protocol (ARP) table in a special type of memory called Content Addressable Memory (CAM).
- ARP table has all the information that which IP address is mapped to which MAC address.

- Two major attacks are possible:
 - MAC Flooding
 - ARP poisoning

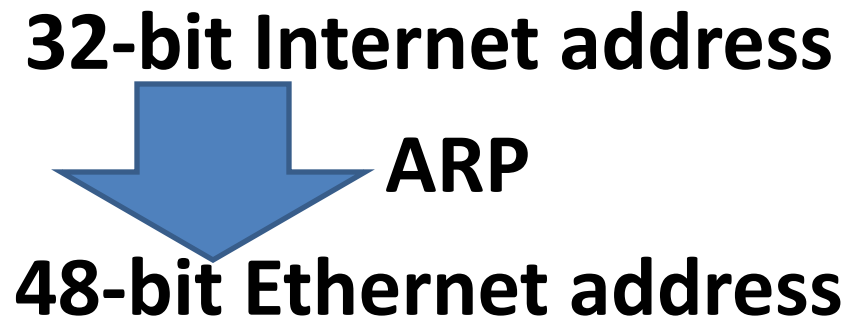
MAC Flooding

- The switch can intelligently route packets from one host to another.
- The switch has limited memory
- The act of overloading the CAM is known as MAC flooding.
- MAC flooding bombard the switch with fake MAC addresses, so that it became saturated

- The switch goes to a *failopen* mode and cannot perform IP to MAC mappings
- It starts behaving like a hub and starts transmitting the data to all machines.

What is ARP?

- Address Resolution Protocol maps IP address to MAC address
- Purpose of ARP



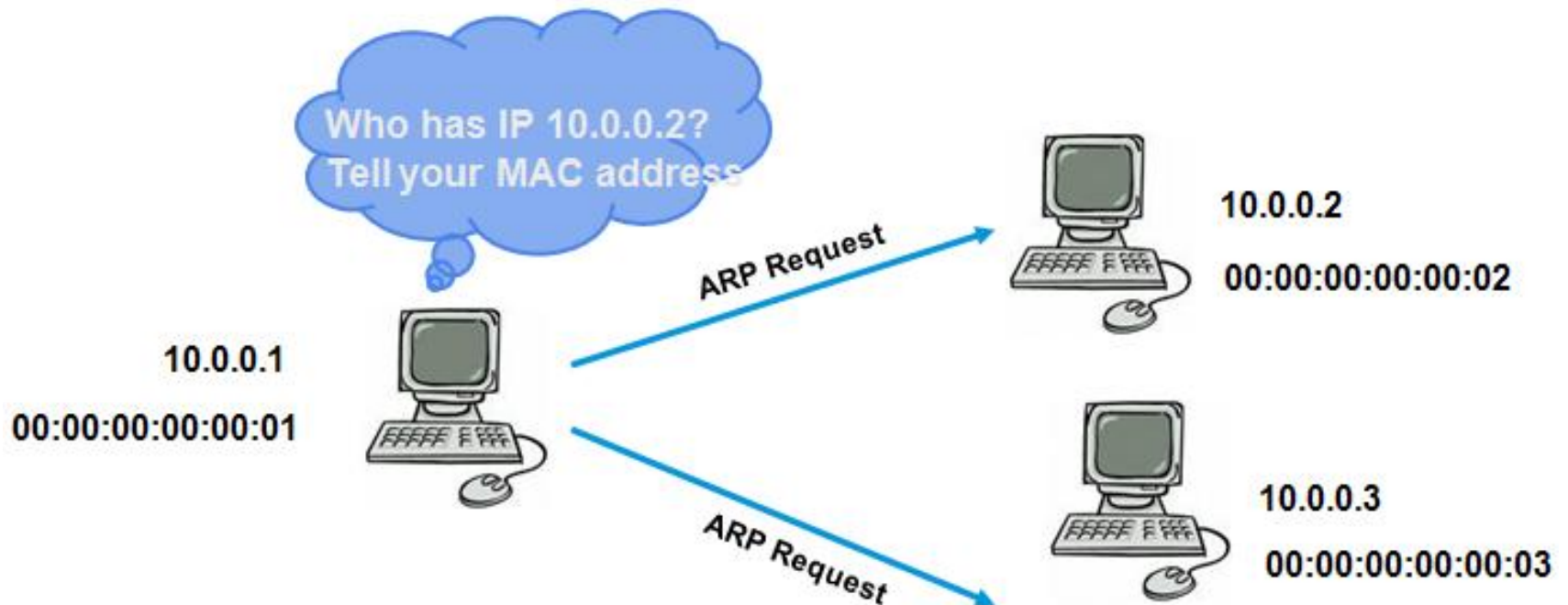
- ARP CACHE : IP – MAC Bindings

IP	MAC	TYPE
10.0.0.2	00:00:00:00:00:02	dynamic

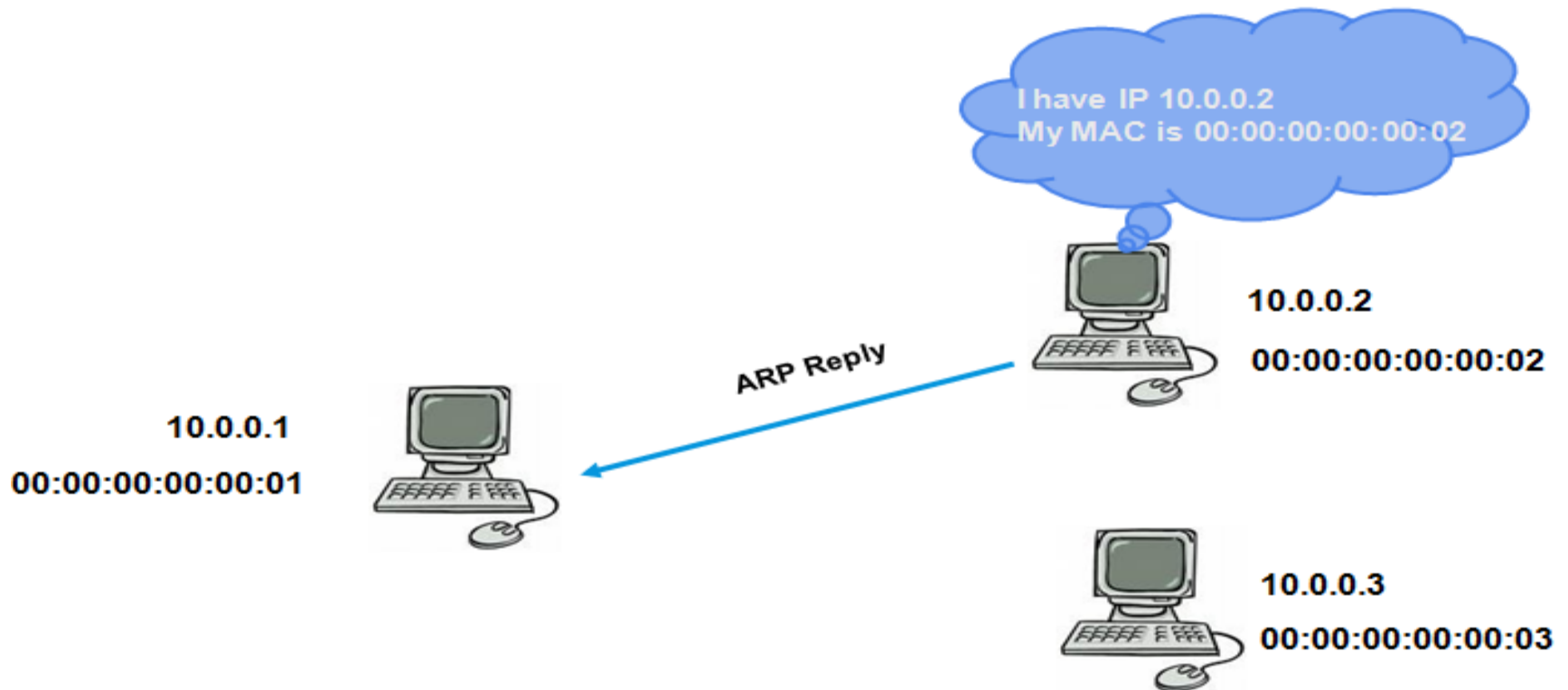
How ARP Works?

- ARP resolves IP addresses to MAC addresses.
- ARP works by **broadcasting** requests and caching responses for future use
- The ARP table is updated whenever an ARP response is received
- Requests are not tracked
- ARP announcements are not authenticated

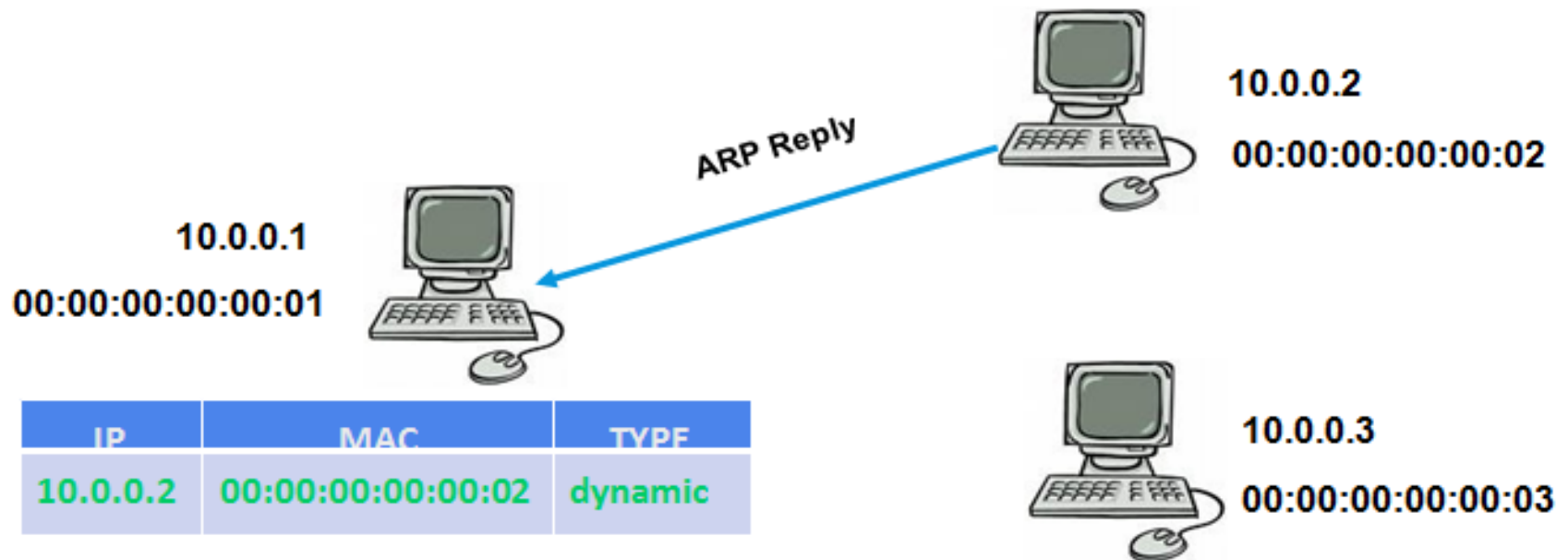
- ARP Request is Broadcast to all the hosts in LAN



- Unicast Reply from concerned host

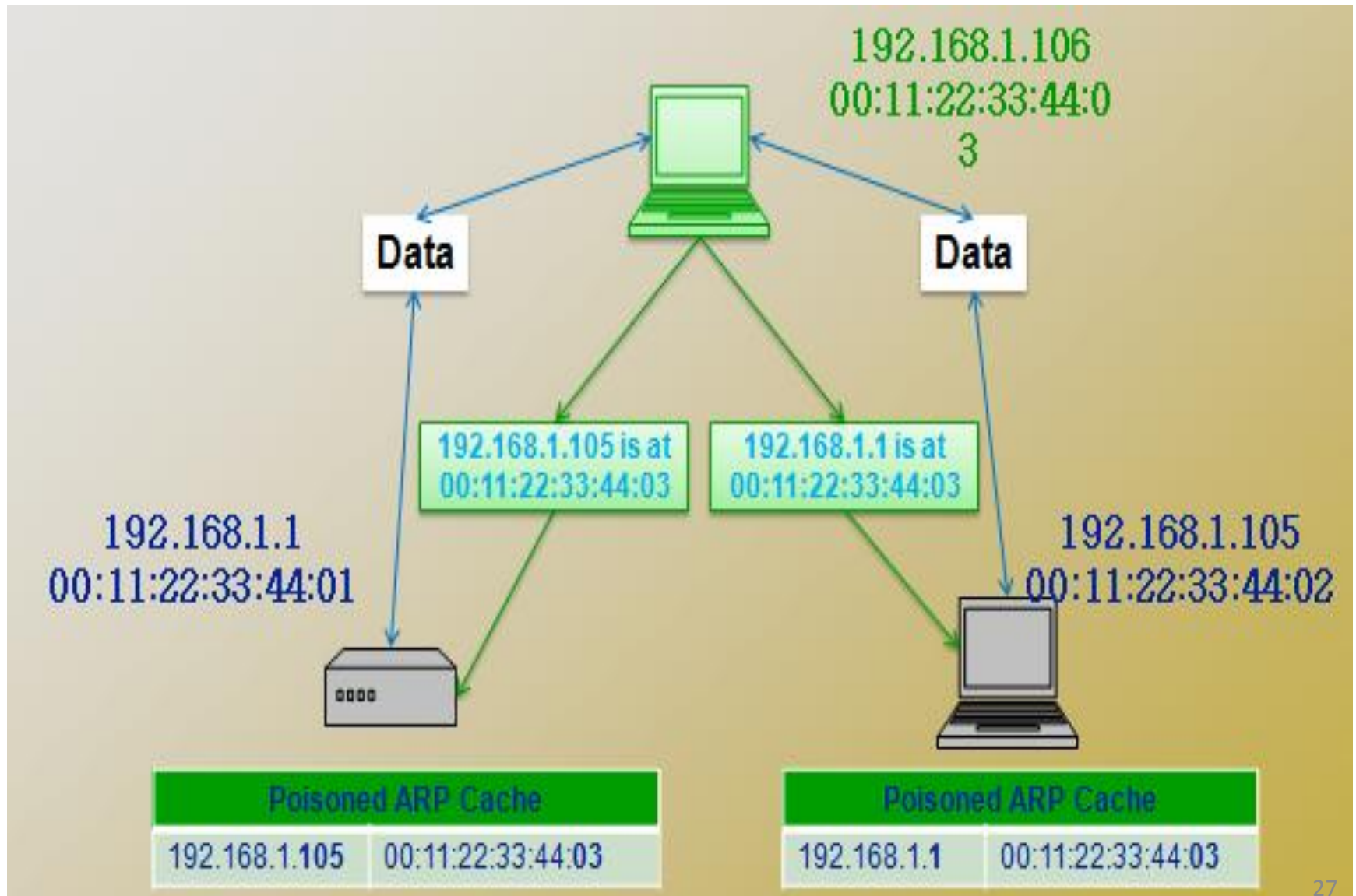


- ARP cache : updated



- Machines trust each other, a rogue machine can spoof other machines
- An ARP cache updates every time that it receives an ARP reply, even if it did not send any ARP request
- It is possible to **poison** an ARP cache by sending **fake ARP replies**

Poisoned ARP Caches



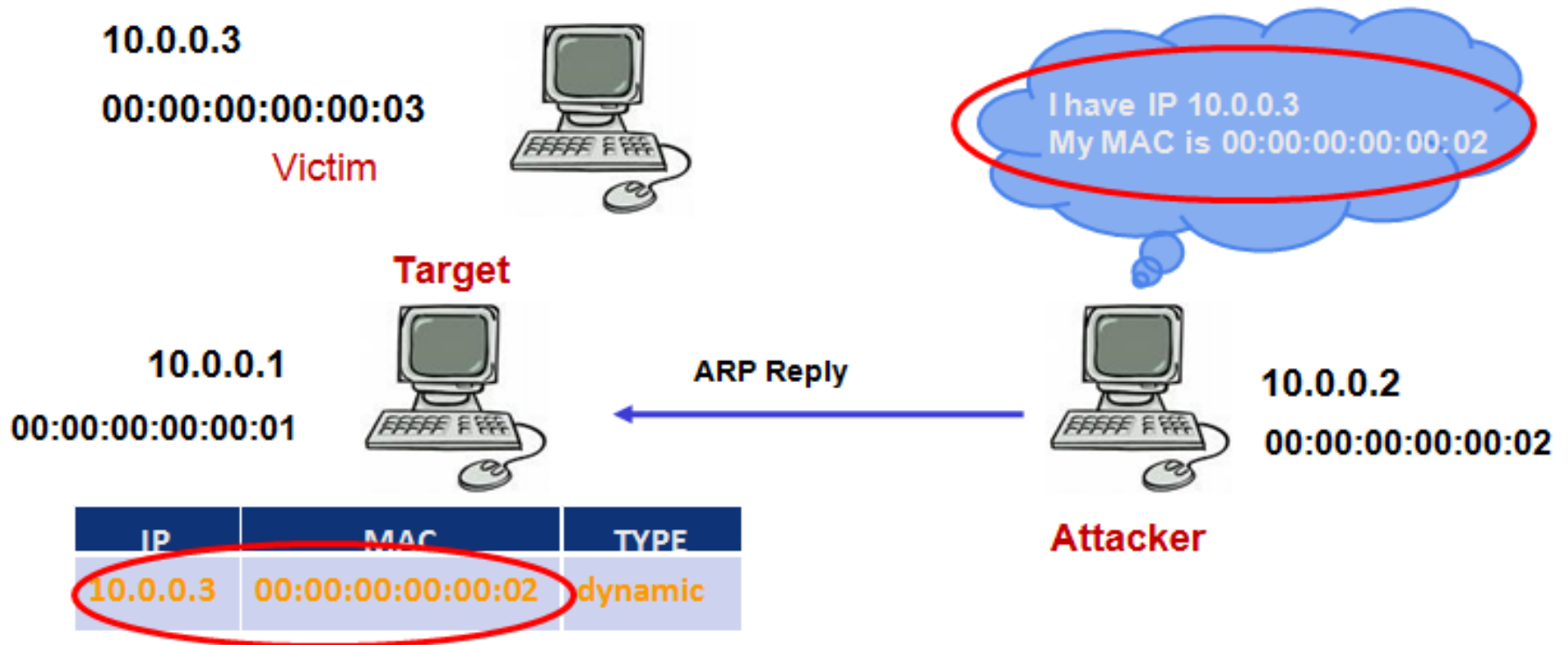
- ARP Vulnerable:
 - ARP is a stateless protocol
 - Hosts cache all ARP replies sent to them even if they had not sent an explicit ARP request for it.
 - No mechanism to authenticate their peer

Known Attacks Against ARP

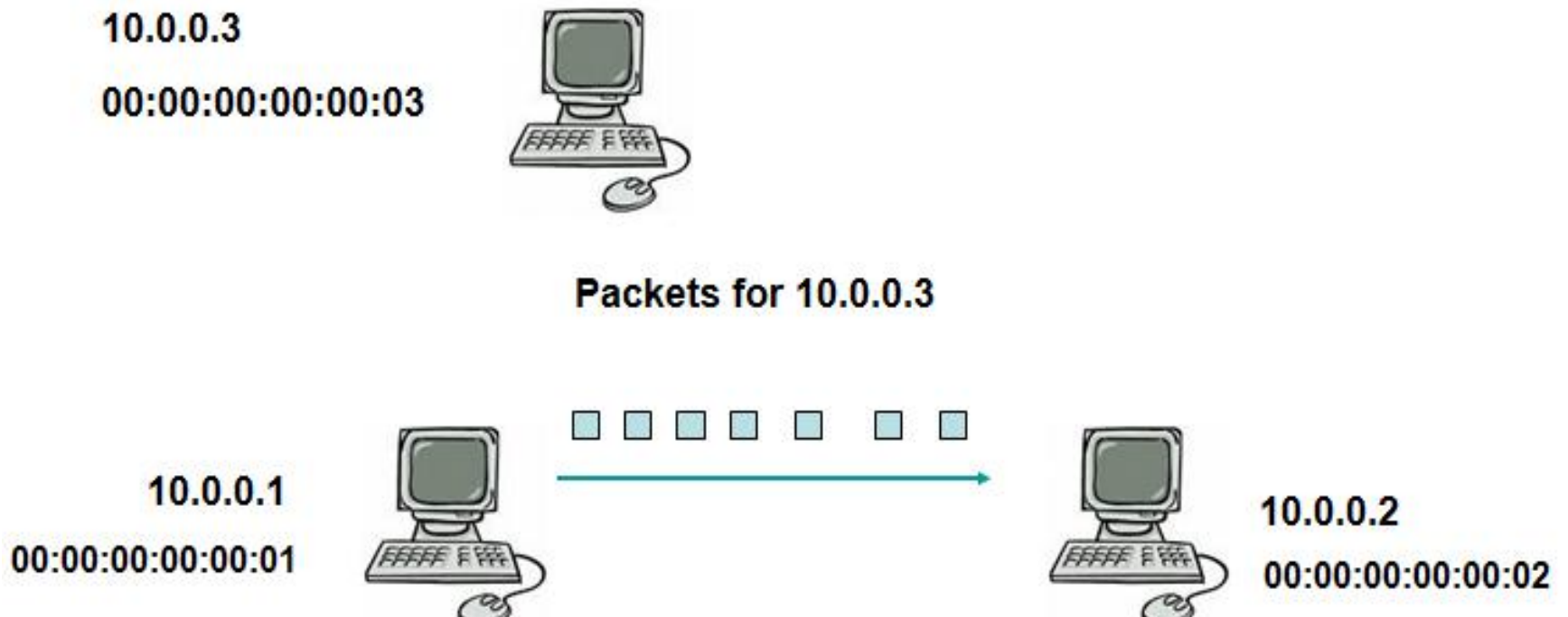
- ARP Spoofing
 - Man-in-the-Middle Attack
 - Denial-of-Service Attack
 - MAC Flooding (on Switch)
 - DoS by spurious ARP packets

ARP Spoofing Attack

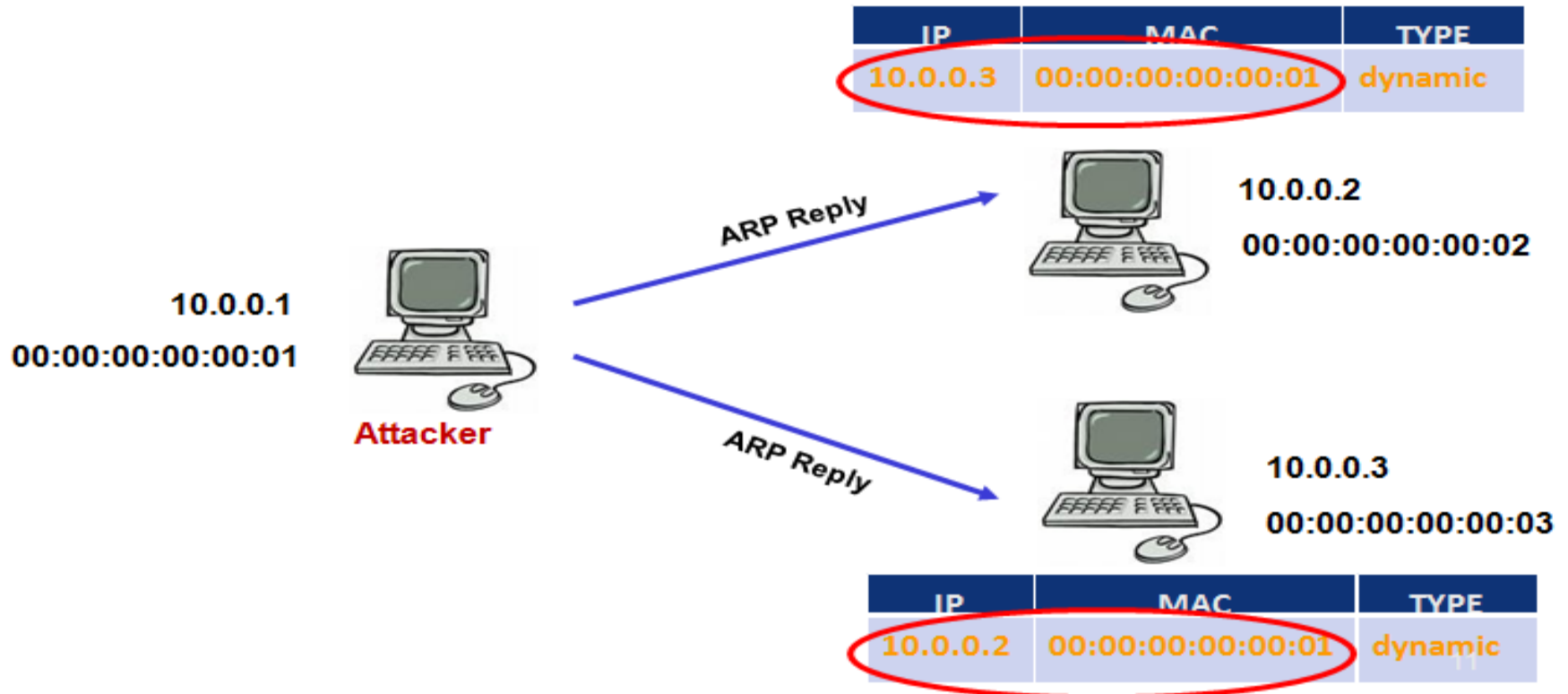
- Attacker sends forged ARP packets to the victim



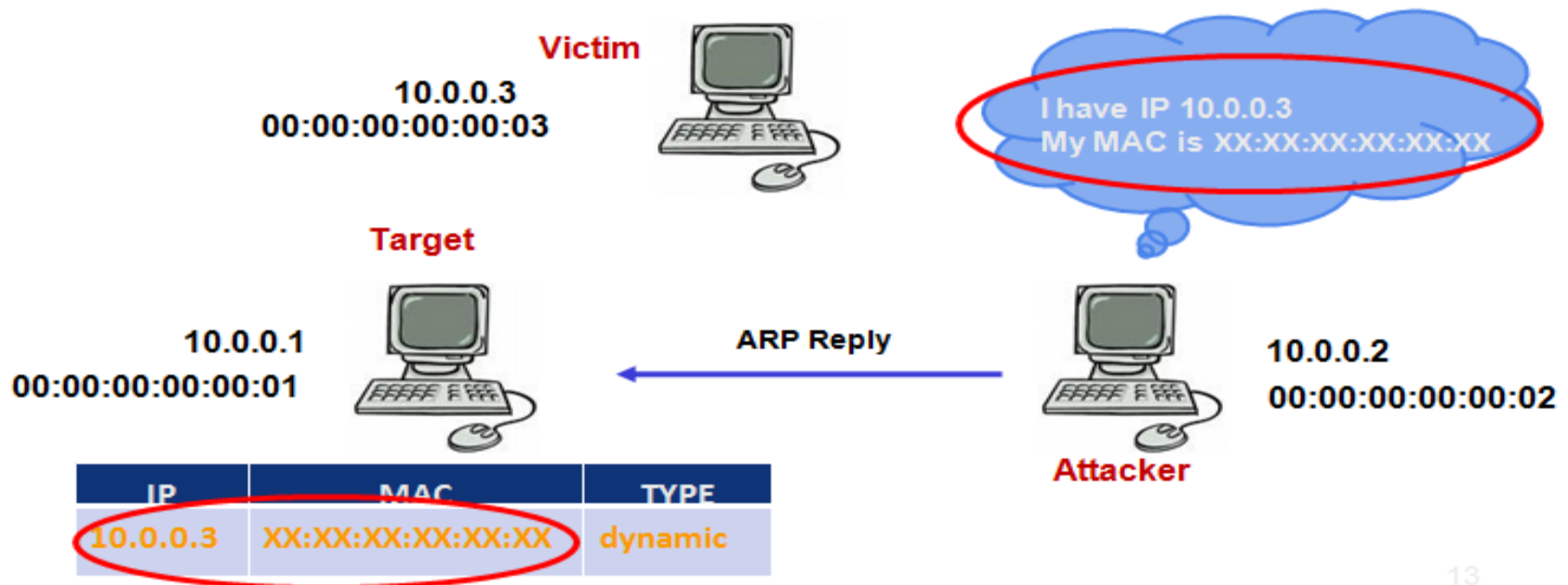
- Spoofing Results in Redirection of Traffic



- Man-in-the-Middle Attack Allows Third Party to Read Private Data



- **Denial of Service** Stops Legitimate Communication.
- A malicious entry with a non-existent MAC address can lead to a DOS attack

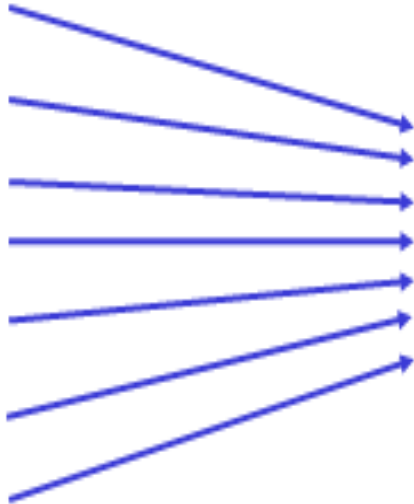


- MAC Flooding Degrades Network Performance
- Attacker bombards the switch with numerous forged ARP packets at an extremely rapid rate such that its CAM table overflows

10.0.0.1
00:00:00:00:00:01



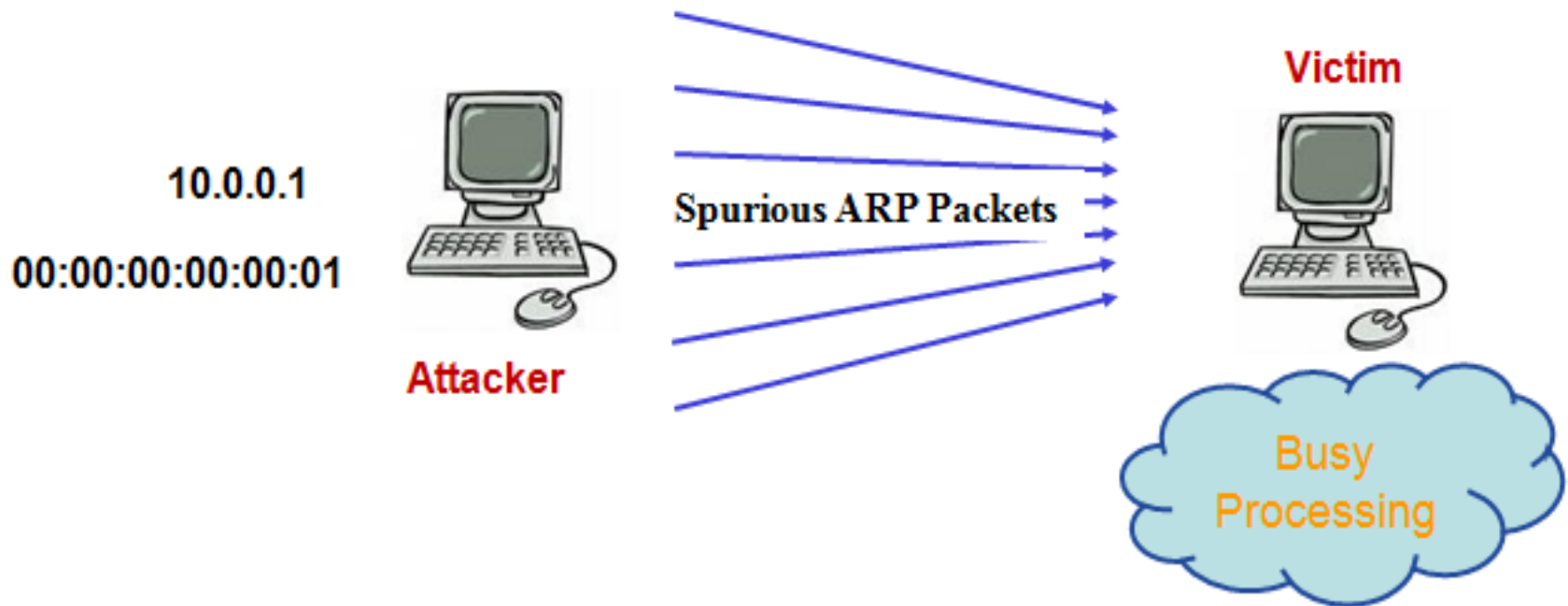
Attacker



PORT	MAC
1	00:00:01:01:01:01
2	00:00:02:02:02:02

DoS by Spurious ARP Packets

- Attacker sends numerous spurious ARP packets at the victim such that it gets engaged in processing these packets
- Makes the Victim busy and might lead to Denial of Service



Detection and Mitigation Techniques

- Static ARP Cache entries—Fixed IP-MAC pairs
- ARPWATCH /COLOSOF CAPSA/ARP-Guard- Maintains a database with IP-MAC mappings and any change detected is reported to administrator
- Count the imbalance in number of requests and responses
- Cryptographic Techniques:
 - Secure ARP – use cryptographic algorithms to authenticate

Port Scan and Ping Sweep

- These are two common network probes typically used to run various test against a host or device to find vulnerable services.
- They are helpful to examine the IP address and the services running on a device or host.

- The most popular probing tool is **Nmap** (Network Mapper)
- Different types of Nmap scans are
 - ***TCP Connect Scan***
 - ***TCP SYN Scan***
 - ***FIN Scan***
 - ***ACK Scan***

- The method of finding that which IP addresses are alive is called **ping sweep**.
- Attacker sends an ICMP packet to each machine (with in a range) to a targeted network.
- ICMP replies from different machines are logged into a file for future reference

Internet Information Queries

- Consists of:
 - DNS queries
 - IP queries
 - Ping sweep
- After these queries, port scan is started by the hacker
 - to find out which ports are open and which services are running on these ports.

Access Attack

- **Access attacks** occur when a malicious hacker exploit **vulnerabilities** and succeed to access the confidential information of any organization.
- Different types of attacks are:
 - Password Attacks
 - Trust Exploitation
 - Port Redirection
 - Man-in-the-middle attack

Password Attack

- Repeated attempts to find the user information (user name or password)
- Types of Password Attack are:
 - Dictionary Attack
 - Brute force attack
 - Hybrid Attack

Types of password Attacks

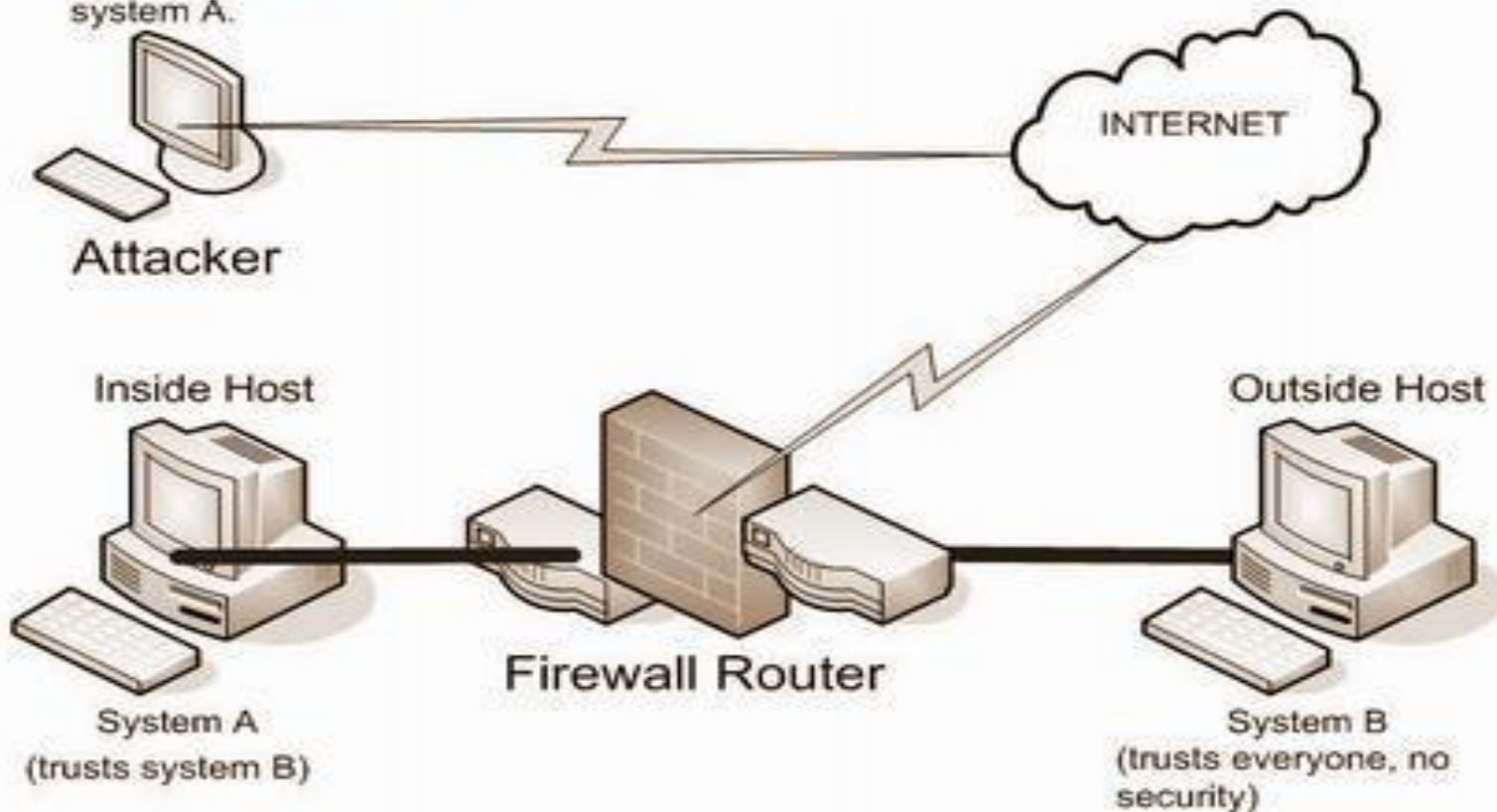
	Dictionary Attack	Brute force Attack	Hybrid Attack
Speed of the Attack	Fast	Slow	Medium
Passwords Cracked	Finds only words	Finds every password(A-Z, 0-9, special characters)	Finds only the password that have a dictionary word as the base

Trust Exploitation

- *Scenario:*
 - When a hacker attacks on a computer which is outside a firewall and that computer has a trust relationship with another computer which is inside the firewall, the hacker can exploit this trust relationship.

Trust Exploitations

If I can gain access to system B, then I will own system A.



Trust Exploitation

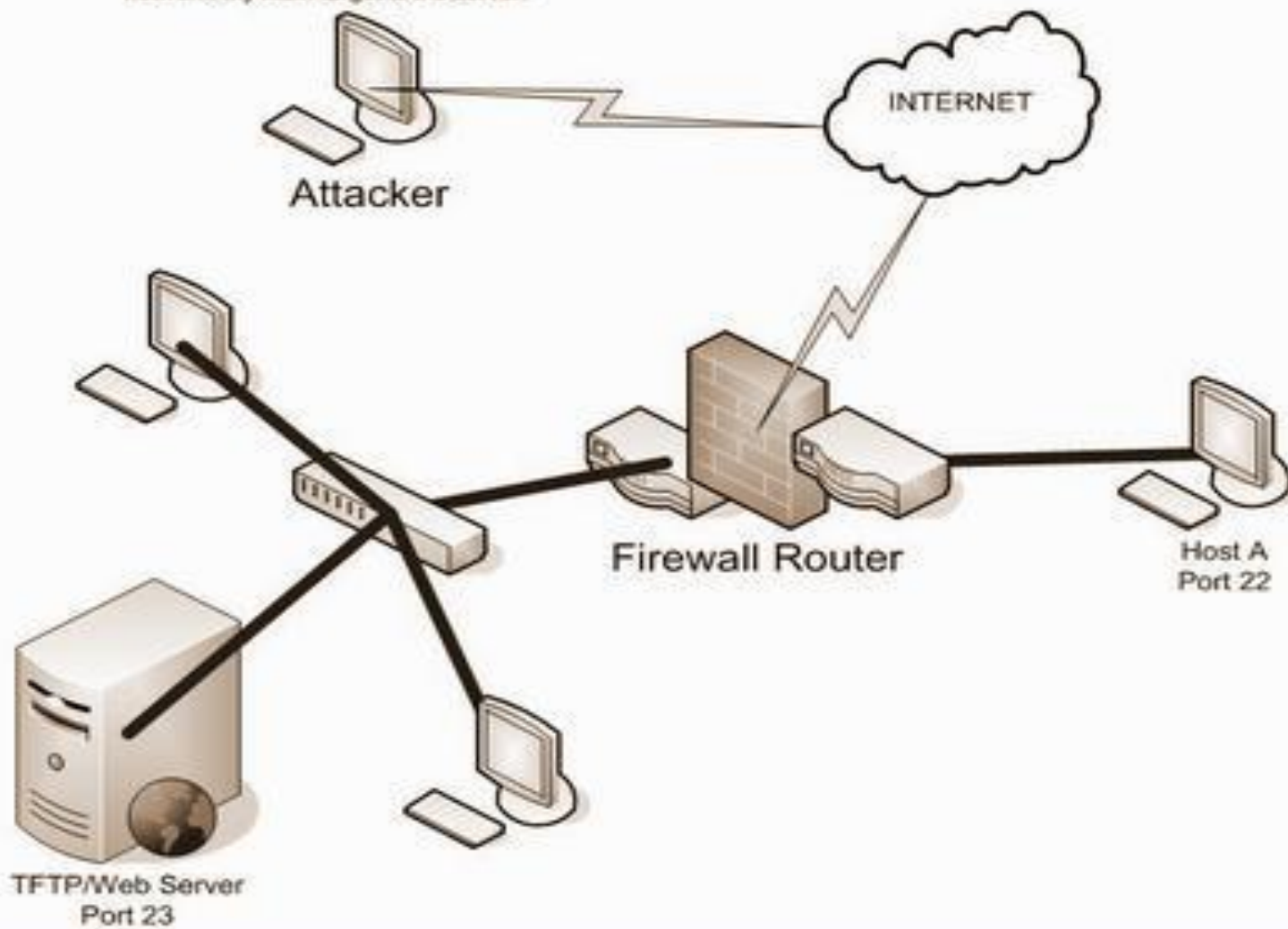
- *Mitigated by:*
 - using private VLANs between switches
 - limiting the trust relationship between systems
 - eliminating useless trust relations between different servers

Port Redirection

- Similar to trust exploitation attack
- The attacker bypasses the security mechanism.
- The attacker installs a software that can redirect the traffic towards the attacker.

Port Redirection

If I can gain access to Host A port 22, then I will install a software to redirect traffic from A into the network. My main target is the server.



Man-in-the-Middle Attack

- The attacker succeed to intrude himself between two communication parties.
- The attacker can
 - **intercept** data between source and destination host
 - **modify** data and retransmit it to the destination host
 - inject any type of false data
- MIM attack can affect on availability, confidentiality, integrity and authenticity of data.

- In a Man-in-the-Middle attack the attacker gets in the middle of a real run of a protocol.

